

Embedly

Embedly is a platform that converts all URLs into embeddable content.

Twitterized Newspaper

BroadFeed, a Twitterized newspaper application for iPad, automatically works with twitter account and organizes the topics based on popularity.

dows, you can encrypt your browser's profile directory using the NTFS' encryption feature and stay relaxed. With Linux, you can encrypt your /home partition and it would be very safe (along with your other documents in the /home partition). If that sounds Greek, there are a few third party tools and Google is your best mate as well.

Cross Site Scripting (XSS)

One might perceive the fact that the way to hack a user's information is by exploiting the loopholes on his computer. While it cannot be denied that the above stands right, there is yet another way where a user can be exploited indirectly through a website. An attacker would write some malicious code on a web page and when a user visits the same page, his information might be stolen. The question is HOW?

Let us consider a simple scenario where a page displays what the user enters in a text input area. A sample of such code (in PHP) would be:

```
$input = $_POST[input];
echo $input;
echo '<div id="message">
</div>';
```

Here the input given by user is stored in the \$input variable and is then printed on screen. We also create a small div on the page whose id we choose to be message, which we will use later. Let us call the script xss.php.

Let us assume the form which submits data to this PHP script is something like:

```
<form action="xss.
php" method="post">
  Enter something: <textarea
name="input"></textarea>
  <input type="submit"
value="test" />
</form>
```

Now, if you scribble anything into the box, it will show you the same exact thing as the output. If you were to type abcd, it will show abcd. But that is not our interest. We want to explore possibilities. So we type something like this in the input box:

```
<script type="text/javas-
cript"> function myfunc()
{ txt = "<p>Current URL:" +
document.location.href + "</p>";
document.
```

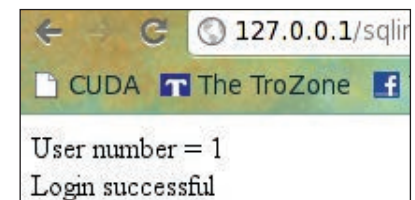
```
getElementById("message") .
innerHTML=txt; } </script>
<span onmouseover=
"myfunc()">Do you want 1 mil-
lion dollars? :)</span>
```

When you submit this data to xss.php, you will see something like:

It looks pretty simple, doesn't it? Just hover the arrow over the text and you will see it isn't as innocent as it looks:

You can see that just a hover over the text made the page extract your current URL and show it on screen. Our input in the form has been crafted for demonstration. A malicious user can write code which would be potent enough to extract a lot more data or perform other actions, without showing anything materialistic on screen and making everything undone for you. If you remember correctly, even extracting URLs can be perilous. If the site does not take care of the session IDs, even this script with slight modifications, can be used to session-hijack the user.

You often enter a lot of data in web forms especially on discussion boards and blogs. An attacker can create a carefully



Successful injection of XSS

sion boards and CMS software would not allow you to enter HTML in the input fields such as comments or article bodies. If you are a site admin, make sure that you do not allow users to use all the available HTML tags. If you are trying to develop a website, do make sure that you allow only basic HTML tags in the input field. There are a lot of open source CMS software projects on the web. You can read the code and implement it in your web application as well (take care of license).

These three vulnerabilities are one of the major reasons why some people do not prefer modified or custom made CMS software for their websites. It is very much possible that the developer while modifying a CMS might have himself disabled one (or more) of the security features for being able to include some new ones which he can advertise about.

Now having read this piece of text, your senses might have been alarmed. However, you need to caress them because for every question, an answer exists. If you do acknowledge the risks that you might be taking, unknowingly, try and counter it, or else, get ready for the heat. It is worth a mention that we showed you less than the tip of the iceberg. There is a whole lot more into each one of these techniques. **d**

A simple example of XSS

crafted script and data which when visited would steal user information, information you'd never have liked to be shared. Since in this method the attacker is targeting the user indirectly by using a script which has been put up on a website, it is called Cross Site Scripting or XSS for short.

Countermeasures

XSS uses the weaknesses of websites. Just leave a single gap and the attacker



Requesting for user response